

Chapter 1 — Overview of Security

CompTIA Security+ Study Slides (Revised)

Walailak University — Assist. Prof. Dr. CJ

Updated from Chapter 1 (EN) and enriched with topics from Sec-L01

Learning Objectives

- Explain **Information Security** and **Information Systems Security** concepts
- Apply the **CIA Triad** and **AAA Model** to real scenarios
- Identify **major security threats** and **threat actors**
- Design **risk-proportionate controls** (physical/technical/administrative)
- Track **security metrics** to drive continual improvement

Information Security — Definition & Goal

Definition: Processes and measures that protect *data* and the *systems that store/process/transmit it* from unauthorized access, use, disclosure, disruption, modification, or destruction.

Goal: Preserve **CIA — Confidentiality, Integrity, Availability**.

notes:

Security = people + process + technology. Not only tools.

Information Systems Security

Focuses on protecting **systems** that store/process/transport information: servers, DBs, networks, endpoints, and cloud services.

System components = **Hardware + Software + People + Processes**

Principles:

- **Risk-based, defense-in-depth**
- **Define secure baselines and minimum security standards**

CIA Triad — Core Principles

Element	Description	Examples
C – Confidentiality	Prevent disclosure to unauthorized subjects	Encryption, Access Control
I – Integrity	Prevent unauthorized alteration; detect changes	Hash, Digital Signature
A – Availability	Ensure timely and reliable access to assets	Backup, Redundancy, Load Balancing

CIA — From Principle to Practice

- **Confidentiality:** Encrypt at rest/in transit; RBAC/ABAC; DLP; MFA
- **Integrity:** SHA-256/512; Code signing; DB constraints/transactions; WORM storage
- **Availability:** HA/Failover; DR/BC (RTO/RPO); Capacity planning; DDoS protection

Metrics: Uptime %, MTTR, data-leak incidents, hash mismatch rate, restore test success

AAA Model — Authentication • Authorization • Accounting

1. Authentication — Prove *who you are*

- Something you **know / have / are / do / where**
- **Phishing-resistant MFA** (FIDO2/WebAuthn), SSO/OIDC, Risk-based/Adaptive auth

2. Authorization — Decide *who can access what*

- RBAC/ABAC/ReBAC, Policy-as-Code, Least privilege, SoD, PAM/JIT/JEA

3. Accounting — Record & verify *who did what, when, where, how*

- Centralized logging/SIEM, immutable/WORM logs, time sync (NTP), retention

AAA — Threats & Mitigations (Quick View)

- **Auth:** Phishing/MitM → FIDO2, proper TLS, short-lived tokens/DPoP, origin checks
- **AuthZ:** Over-permission/Privilege escalation → Access reviews, Patch, PAM
- **Accounting:** Incomplete/tempered logs → Immutable store, split duties, log integrity

Security Threats — Categories

Category	Examples
Malware	Virus, Worm, Trojan, Ransomware, Spyware/Keylogger, Rootkit, Botnet
Unauthorized Access	Credential theft/stuffing, Phishing, Privilege escalation, Insecure API
System Failure	Hardware/Software failure, Misconfiguration, Capacity/Performance
Social Engineering	Phishing/Smishing/Vishing, Pretexting, Baiting, Tailgating, MFA fatigue

Threats → Controls (Mapping)

- **Malware:** EDR + Patch + Allow-list + Network segmentation + Immutable backup
- **Unauthorized Access:** MFA, SSO/Federation, PAM/JIT, resource-level API AuthZ
- **System Failure:** HA/Failover, IaC + policy-as-code, Chaos testing, SLO/SLA
- **Social Engineering:** Scenario-based awareness, Email/SMS filtering, Safe-link rewrite

Mitigating Threats — Control Classes

Physical: Doors/locks, CCTV, Mantrap, Visitor badges

Technical: MFA, RBAC/ABAC, Hardening, Patching, IDS/IPS/NDR, Encryption

Administrative: Policies, Secure SDLC, Change mgmt, BCP/DRP, Awareness

Control roles: Preventive • Detective • Corrective/Recovery • Deterrent • Compensating

Minimum Viable Controls (Modern Baseline)

1. **Identity-first:** Phishing-resistant MFA (FIDO2/Passkeys) + SSO/Federation + quarterly access reviews
2. **Endpoint/Server:** EDR + auto-patch + secure baseline + full-disk encryption
3. **Network:** Macro/Micro-segmentation, least-privilege egress, WAF/IPS, DNS security
4. **Backup/DR:** Offline/immutable backups + periodic RTO/RPO testing
5. **Detect & Respond:** Centralized logging → SIEM, SOAR playbooks, measurable MTTR
6. **Awareness:** Phishing simulations + strong reporting culture

Hackers & Threat Actors

Traditional “hats”: White / Black / Gray / Blue / Elite / Script Kiddie

Contextual actors: Hacktivist, Organized Crime, APT/State-sponsored, Insider, Cyber Terrorist, Mercenary, Competitor/Industrial Spy

Analysis frame: Motivation • Capability • Resources • Opportunity

Lifecycle: Recon → Initial Access → Escalation → Persistence → Lateral → Collection → Exfil/Impact

Strategic Defensive Posture

- **Zero Trust & Identity-first:** continuous verification, least privilege, micro-segmentation
- **Defense-in-Depth:** layered controls across Endpoint–Network–App–Data
- **Supply Chain Security:** SBOM, Code signing, CI/CD security, Secrets management
- **IR/BCP/DR:** Runbooks/Playbooks, Tabletop & technical drills, Post-incident reviews



Security Metrics

- **MTTD/MTTR, Patch latency, Backup health & restore success**
- **Access review completion & removal of excessive privileges**
- **Phishing resilience rate & suspicious-email reporting rate**



Summary

- **CIA** and **AAA** are foundational to security design
- Threats span people–process–technology → require **defense-in-depth**
- Choose controls **proportionate to risk** and monitor with clear **metrics**
- Culture and continuous learning strengthen resilience over time

Discussion Prompts

1. How would you prioritize CIA for OT vs. IT systems?
2. Which MFA methods are phishing-resistant and why?
3. Propose a Minimum Control set for a new internal web app

End of Chapter 1

"Security is a process, not a product." — *Bruce Schneier*